2026

Plan de Comunicación de Crisis

CNO IV: SEGURIDAD INFORMÁTICA

ALEJANDRO GARCIA MORALES

1. Contexto de la Crisis (Criterio PR02-21)

1.1 Descripción General del Incidente

De acuerdo con los hallazgos documentados en el Informe Técnico de Seguridad Ofensiva sobre INTERAFAS-LAB, el incidente objeto del presente plan corresponde a una cadena de ataque convergente IT→OT que inició con fallas de exposición de información en el portal público de INTERAFAS (archivos residuales, respaldos de código fuente y metadatos de compilación), escaló mediante el compromiso de sesiones, controles de acceso y APIs ciudadanas (IDOR, BOLA, escalada de privilegios y Cross-Site Scripting persistente), y culminó con el pivote lateral hacia la red de Tecnologías de la Operación a través de la pasarela /operations/gateway.php, el abuso de una credencial de mantenimiento heredada y la alteración no autorizada del parámetro de presión del gateway RTU-GW-07, provocando una condición de sobrepresión y el estado declarado como CATASTROPHIC STATE en la estación de bombeo primario.

Para efectos de este plan de comunicación, el incidente se clasifica como un Incidente de Ciberseguridad con Impacto Físico en Infraestructura Crítica (convergencia IT/OT), dado que no se limita a la fuga o alteración de información, sino que generó —en el entorno simulado— una afectación potencial a la continuidad del servicio de agua potable y a la integridad física de activos de bombeo.

1.2 Afectaciones Identificadas

Dimensión	Afectación Observada
Confidencialidad de datos ciudadanos	Exposición y acceso no autorizado a expedientes, historiales de consumo y datos contractuales de usuarios de INTERAFAS (IDOR / BOLA), con riesgo de divulgación masiva del padrón de cuentas.
Integridad de procesos de negocio	Manipulación de montos de pago y de validaciones de vínculo proveedor-contrato, con riesgo de afectación patrimonial y de legitimidad en procesos de contratación.
Disponibilidad y seguridad física (OT)	Alteración del punto de ajuste de presión del gateway RTU-GW-07 fuera de los límites seguros de ingeniería, con cascada de sobrepresión, saturación de alarmas y caída de disponibilidad del proceso de bombeo primario.
Reputación institucional	Exposición pública potencial del incidente a través de medios digitales y redes sociales, con riesgo de erosión de la confianza ciudadana en la capacidad de INTERAFAS para garantizar el suministro seguro de agua potable.
Cumplimiento y regulación	Posible obligación de notificación a autoridades sectoriales y de protección de datos personales, derivada del acceso no autorizado a información de usuarios.

1.3 Escenario Reputacional y Cobertura Mediática

El escenario reputacional de este plan se construye a partir del monitoreo del portal periodístico simulado "Pulso Metropolitano" (interafas-lab-news-1) y de las reacciones de actores internos y externos registradas durante la interacción con INTERAFAS-LAB. En este punto, el plan requiere la incorporación de la evidencia observada directamente en el laboratorio (titulares publicados, tono de la cobertura, actores citados, comentarios ciudadanos y cualquier declaración oficial o extraoficial capturada durante el ejercicio), a efecto de calibrar con precisión la magnitud reputacional del incidente y los mensajes de respuesta.

2. Gobierno de la Comunicación (Criterio PR02-22)

El gobierno de la comunicación de crisis de INTERAFAS se estructura mediante un Comité de Crisis de Comunicación (CCC), subordinado al Comité de Gestión de Incidentes de Ciberseguridad institucional, con roles, responsabilidades y niveles de autorización claramente delimitados, a fin de evitar mensajes contradictorios, filtraciones no controladas o demoras en la respuesta.

2.1 Estructura de Roles y Responsabilidades

Rol	Titular / Área	Responsabilidad Principal
Patrocinador Ejecutivo	Dirección General de INTERAFAS	Autoriza el nivel de respuesta institucional, aprueba la estrategia general de comunicación y es el responsable último ante el Consejo Directivo y las autoridades.
Vocero Principal	Director(a) de Comunicación Social e Imagen Institucional	Única persona autorizada para emitir declaraciones públicas oficiales (medios, ruedas de prensa, redes sociales institucionales).
Vocero Suplente	Subdirector(a) de Comunicación Social / Enlace de Relaciones Públicas	Asume la vocería en ausencia, indisponibilidad o conflicto de agenda del Vocero Principal, bajo las mismas restricciones de autorización.
Líder de Ciberseguridad (CISO)	Jefatura de Seguridad de la Información / CISO de INTERAFAS	Valida técnicamente el contenido de los mensajes para asegurar exactitud y evitar la divulgación de datos sensibles que faciliten nuevos ataques.
Enlace Jurídico	Dirección de Asuntos Jurídicos	Revisa y autoriza el contenido desde la perspectiva de responsabilidad legal, protección de datos personales y obligaciones de notificación regulatoria.
Enlace de Alta Dirección / OT	Dirección de Operación Hidráulica	Provee el estado real del proceso físico (bombeo, presión, disponibilidad del servicio) para que los mensajes reflejen la condición operativa vigente.
Coordinador del Comité de Crisis	Gerencia de Riesgos y Continuidad del Negocio	Convoca, da seguimiento a acuerdos, controla el registro de decisiones (bitácora) y verifica el cumplimiento de los tiempos de respuesta establecidos en este plan.
Responsable de Monitoreo de Medios	Analista de Comunicación Digital	Monitorea medios, redes sociales y foros en tiempo real, y alimenta al Comité con el estado de la conversación pública (ver numeral 7).

2.2 Cadena de Autorización

Ningún comunicado, publicación o declaración relacionada con el incidente podrá difundirse sin seguir la siguiente cadena de autorización secuencial:

- 1. Redacción del mensaje por el Vocero Principal (o Suplente) con apoyo del Responsable de Monitoreo de Medios.
- 2. Validación técnica por el CISO (exactitud de hechos, estado del incidente, ausencia de información que comprometa la contención).

- 3. Validación jurídica por el Enlace Jurídico (cumplimiento regulatorio, protección de datos personales y riesgo de responsabilidad).
- 4. Autorización final del Patrocinador Ejecutivo (Dirección General), quien puede delegar expresamente esta función en el Coordinador del Comité de Crisis para mensajes de bajo impacto.
- 5. Publicación/difusión por el Vocero Principal a través del canal correspondiente, con registro inmediato en la bitácora de decisiones (ver numeral 10.2).

En situaciones de Nivel 3 o 4 (ver numeral 5), la autorización final del Patrocinador Ejecutivo es indelegable y debe constar por escrito o en el acta de sesión del Comité de Crisis.

2.3 Participantes en la Toma de Decisiones de Comunicación

El Comité de Crisis de Comunicación sesiona de manera extraordinaria mientras dure la activación del plan, con la participación obligatoria del Vocero Principal (o Suplente), el CISO, el Enlace Jurídico, el Enlace de Alta Dirección/OT y el Coordinador del Comité. De forma consultiva, y según la etapa del incidente, se incorpora al Líder del Equipo de Respuesta a Incidentes (CSIRT) y, en escenarios de Nivel 3 o 4, a un enlace de Recursos Humanos (comunicación interna al personal) y a un enlace de Relación con Autoridades.

3. Objetivos y Principios de Actuación (Criterio PR02-23)

3.1 Objetivos Comunicacionales

- Informar de manera oportuna, veraz y proporcional a los públicos internos y externos sobre la existencia, alcance y evolución del incidente de ciberseguridad.
- Proteger la confianza ciudadana en la capacidad de INTERAFAS para garantizar el suministro seguro y continuo de agua potable, sin minimizar ni negar hechos confirmados.
- Evitar la propagación de información imprecisa, rumores o desinformación que agraven la percepción pública del incidente.
- Resguardar la información técnica sensible cuya divulgación pudiera facilitar la explotación adicional de las vulnerabilidades identificadas o poner en riesgo la seguridad física de la operación.
- Dar certeza a los públicos sobre las acciones de contención, remediación y recuperación emprendidas por INTERAFAS, así como sobre los canales disponibles para resolver dudas o reportar afectaciones.
- Facilitar el cumplimiento de las obligaciones regulatorias de notificación a autoridades competentes en materia de protección de datos personales e infraestructura crítica.

3.2 Principios de Actuación

Principio	Descripción Operativa
Oportunidad	Toda comunicación relevante se emite dentro de las ventanas de tiempo establecidas en el numeral 5, evitando tanto el silencio prolongado como la precipitación sin validación técnica/jurídica.
Precisión	Los mensajes únicamente afirman hechos confirmados por el CISO y el equipo de respuesta a incidentes; lo que aún se encuentra en investigación se comunica expresamente como tal.

Consistencia	Un único vocero autorizado por mensaje y un mensaje central ("single source of truth") validado por el Comité de Crisis, evitando versiones divergentes entre canales o portavoces.
Transparencia	Se reconoce el incidente, su naturaleza general y su impacto, evitando minimizaciones, sin que ello implique divulgar detalles técnicos explotables.
Protección de la información sensible	Se excluye de toda comunicación pública el detalle técnico de vulnerabilidades no remediadas, credenciales, direcciones IP internas, nombres de archivos de configuración o cualquier dato que facilite un ataque adicional (ver numeral 7.3).
Empatía y responsabilidad	El tono institucional reconoce la preocupación legítima de la ciudadanía y del personal, evitando lenguaje defensivo o evasivo.

4. Públicos y Canales de Comunicación (Criterio PR02-24)

La identificación de públicos y canales se realiza distinguiendo entre audiencias internas (personal, Consejo Directivo) y externas (ciudadanía, medios, proveedores, autoridades), asignando a cada una el canal más apropiado según su nivel de formalidad, alcance y velocidad requerida.

4.1 Públicos Internos

Público Interno	Interés / Necesidad de Información	Canal Asignado
Consejo Directivo / Alta Dirección	Magnitud real del incidente, riesgo reputacional, financiero y operativo, decisiones que requieren su aprobación.	Sesión extraordinaria / informe ejecutivo confidencial + correo cifrado institucional.
Personal operativo (Centro de Operaciones, bombeo primario)	Instrucciones de seguridad física, cambios en procedimientos operativos, estado real de la planta.	Comunicado interno urgente + radio/telefonía operativa + reunión de turno.
Personal administrativo y atención ciudadana	Mensajes autorizados para responder a consultas de usuarios, evitar especulación interna.	Correo institucional + Intranet + guion de atención (FAQ interno).
Área jurídica, TI/CISO y CSIRT	Coordinación técnica y legal en tiempo real durante la gestión del incidente.	Canal dedicado de crisis (sala de guerra virtual) + bitácora compartida.
Sindicato / representación de personal (si aplica)	Afectaciones a condiciones de trabajo o seguridad del personal de planta.	Comunicado formal dirigido + reunión con representantes.

4.2 Públicos Externos

Público Externo	Interés / Necesidad de Información	Canal Asignado
Ciudadanía / usuarios del servicio	Continuidad y seguridad del suministro de agua, afectación a sus datos personales, qué hacer si fueron afectados.	Sitio web institucional (banner de aviso), redes sociales oficiales, línea telefónica de atención ciudadana.
Medios de comunicación (incl. "Pulso Metropolitano")	Hechos confirmados, postura oficial, cronología y acciones de remediación.	Boletín de prensa (holding statement / comunicado formal), rueda de prensa o entrevista con el Vocero Principal.
Autoridades reguladoras y de protección de datos	Cumplimiento de obligaciones de notificación, alcance del incidente, medidas correctivas.	Notificación formal por escrito (oficio) + reunión de seguimiento, conforme a los plazos regulatorios aplicables.

Proveedores y contratistas	Posible afectación a procesos de contratación, continuidad de pagos y relación contractual.	Comunicado formal dirigido + correo institucional del área de Proveeduría.
Organismos de protección civil / seguridad pública	Riesgo físico derivado de la afectación al proceso de bombeo (si corresponde).	Notificación directa por protocolo de emergencias + enlace telefónico permanente.
Comunidad técnica / investigadores de seguridad	Reconocimiento del hallazgo (si aplica divulgación coordinada) y canal de contacto responsable.	Correo dedicado de seguridad (security@interafas, simulado) y, en su caso, aviso de seguridad técnico.

5. Activación y Escalamiento del Plan (Criterio PR02-25)

5.1 Detonante de Activación

El presente plan se activa de manera automática en cuanto el Equipo de Respuesta a Incidentes (CSIRT) de INTERAFAS confirma, con base en el Informe Técnico de Seguridad Ofensiva y/o en el monitoreo operativo del Centro de Operaciones, la existencia de un incidente de ciberseguridad con al menos una de las siguientes condiciones: (i) acceso no autorizado confirmado a datos personales de usuarios; (ii) evidencia de pivote o acceso no autorizado hacia la red de Tecnologías de la Operación; (iii) alteración no autorizada de parámetros de proceso físico (p. ej., pressure_setpoint_bar); o (iv) cobertura mediática o actividad en redes sociales que haga referencia pública al incidente, con independencia de su exactitud.

5.2 Niveles de Crisis

Nivel	**Descripción**	**Ejemplo (según hallazgos INTERAFAS-LAB)**	**Responsable de Declarar**
Nivel 1 — Vigilancia	Hallazgo técnico interno sin evidencia de explotación activa ni visibilidad pública.	Hipótesis en investigación (p. ej., Retos 07 y 13 en fase de validación en Burp Suite).	CISO
Nivel 2 — Incidente Controlado	Vulnerabilidad confirmada y explotada en entorno IT, con impacto acotado a datos o procesos de negocio, sin pivote a OT ni cobertura mediática significativa.	IDOR/BOLA confirmados (Retos 03, 11, 12) o Stored XSS (Reto 08).	CISO + Coordinador del Comité de Crisis
Nivel 3 — Crisis Reputacional/Regulatoria	Incidente con exposición pública (medios/redes), afectación confirmada a datos personales a escala, o inicio de obligaciones de notificación regulatoria.	Escalada de privilegios (Reto 06) combinada con cobertura en "Pulso Metropolitano".	Patrocinador Ejecutivo, a propuesta del Comité de Crisis
Nivel 4 — Crisis Crítica / Impacto Físico	Compromiso confirmado del entorno OT con riesgo o materialización de afectación física al proceso de bombeo	Alteración de pressure_setpoint_bar en RTU-GW-07 (Reto 20), con cascada de sobrepresión.	Patrocinador Ejecutivo (Dirección General), activación inmediata del

	(CATASTROPHIC STATE).		Comité de Crisis en pleno

5.3 Condiciones para Aumentar o Reducir el Nivel de Respuesta

- Se escala al nivel inmediato superior cuando el CSIRT confirma nueva evidencia de explotación, cuando se detecta pivote hacia la red OT, o cuando el Responsable de Monitoreo de Medios reporta un incremento sostenido de menciones públicas o la publicación de una nota periodística (ver numeral 7).
- Se escala directamente a Nivel 4, sin pasar secuencialmente por los niveles previos, ante cualquier evidencia de alteración de parámetros físicos de proceso (p. ej., setpoints de presión, caudal o válvulas) fuera de los límites seguros de ingeniería.
- Se reduce el nivel únicamente cuando el CSIRT confirma la contención técnica del vector de ataque y el Comité de Crisis verifica, durante al menos un ciclo de monitoreo (ver numeral 7.1), la estabilización de la cobertura mediática y de la conversación en redes sociales.
- El escalamiento y el des-escalamiento se registran formalmente en la bitácora de decisiones (numeral 10.2), indicando responsable, hora y justificación técnica.

6. Mensajes Clave por Etapa (Criterio PR02-26)

Los siguientes son borradores de mensajes clave, sujetos a validación del Comité de Crisis conforme a la cadena de autorización del numeral 2.2, y a la incorporación de los datos específicos observados en INTERAFAS-LAB en los puntos señalados.

6.1 Etapa de Reconocimiento Inicial

Objetivo: confirmar que INTERAFAS tiene conocimiento del incidente, sin especular sobre causas o alcance.

INTERAFAS tiene conocimiento de actividad inusual en algunos de sus sistemas informáticos, y ha activado de manera inmediata sus protocolos internos de seguridad para investigar el alcance de la situación. No contamos aún con información confirmada sobre el impacto en los servicios a la ciudadanía. Mantendremos informados a nuestros usuarios conforme contemos con datos verificados.

6.2 Etapa de Investigación

Objetivo: transmitir que el incidente se está analizando técnicamente, sin confirmar detalles que puedan ser inexactos o explotables.

Nuestro equipo de ciberseguridad, en coordinación con especialistas externos, se encuentra investigando el origen y alcance del incidente detectado. Como medida preventiva, hemos restringido el acceso a ciertos módulos del portal de servicios en línea. La operación del suministro de agua potable se mantiene estable. Actualizaremos esta información en cuanto dispongamos de hallazgos verificados.

6.3 Etapa de Contención

Objetivo: comunicar las acciones concretas tomadas para detener la propagación del incidente.

INTERAFAS informa que ha implementado medidas de contención, incluyendo el aislamiento de los sistemas afectados y el refuerzo de los controles de acceso a nuestra infraestructura. Estas acciones

buscan evitar que la situación se extienda y proteger tanto la información de nuestros usuarios como la continuidad del servicio. Continuamos trabajando con el máximo nivel de prioridad."

6.4 Etapa de Afectación (Comunicación de Impacto Confirmado)

Objetivo: reconocer de forma clara y responsable el impacto confirmado, con base en los hallazgos técnicos verificados.

Como resultado de nuestra investigación, confirmamos que el incidente permitió el acceso no autorizado a información de de un grupo de usuarios de INTERAFAS, y generó una afectación temporal en nuestros procesos operativos de bombeo, la cual fue contenida sin poner en riesgo el abasto de agua potable a la población. Hemos notificado a las autoridades competentes y estamos en contacto directo con las personas afectadas para brindarles orientación.

6.5 Etapa de Recuperación

Objetivo: informar sobre el restablecimiento de la normalidad y las medidas de fortalecimiento implementadas.

Borrador sugerido: *"Nos complace informar que, tras un proceso riguroso de remediación y validación técnica, nuestros sistemas y procesos operativos han sido restablecidos a condiciones normales de operación. Hemos reforzado nuestros controles de ciberseguridad, incluyendo la segmentación de nuestras redes de tecnología de la información y de operación, y continuaremos fortaleciendo estos mecanismos de forma permanente."*

6.6 Etapa de Cierre

Objetivo: cerrar formalmente el ciclo de comunicación pública del incidente, agradeciendo la confianza y reforzando el compromiso institucional.

Borrador sugerido: *"INTERAFAS da por concluida la atención del incidente de ciberseguridad informado el [fecha]. Agradecemos la confianza y paciencia de la ciudadanía durante este proceso. Como parte de nuestro compromiso permanente con la seguridad de la información y la continuidad del servicio, hemos incorporado las lecciones aprendidas de este incidente a nuestros protocolos institucionales, de conformidad con el informe de cierre correspondiente."*

7. Monitoreo de Medios, Redes Sociales y Gestión de Desinformación (Criterio PR02-27)

7.1 Protocolo de Monitoreo

- El Responsable de Monitoreo de Medios da seguimiento continuo, durante la activación del plan, al portal "Pulso Metropolitano" y a las demás fuentes periodísticas y redes sociales que mencionen a INTERAFAS o al incidente.
- Se establece un ciclo de reporte al Comité de Crisis cada 60 minutos en Nivel 3 y Nivel 4, cada 4 horas en Nivel 2, y de forma diaria en Nivel 1.
- Cada reporte documenta: volumen de menciones, tono (positivo/neutro/negativo), principales actores que amplifican el mensaje, y presencia de datos inexactos o no confirmados.

7.2 Tratamiento de Rumores e Información Falsa

- Todo rumor o dato impreciso identificado se documenta en el registro de monitoreo, evaluando su alcance (viralidad) y su potencial de daño antes de decidir si amerita una respuesta pública específica o si basta con reforzar el mensaje oficial vigente.
- La corrección de información falsa se realiza exclusivamente a través del Vocero Principal o los canales oficiales de INTERAFAS, citando hechos verificados, sin reproducir ni amplificar textualmente el contenido falso.
- No se responde de manera individual a cada publicación o comentario; se privilegia la emisión de comunicados centralizados y, en su caso, una sección de Preguntas Frecuentes actualizada en el sitio institucional.

7.3 Tratamiento de Filtraciones de Información Técnica

- Si se detecta la filtración o publicación de detalles técnicos de la vulnerabilidad (p. ej., rutas de endpoints, credenciales o parámetros de configuración), el CISO evalúa de inmediato si dicha filtración incrementa el riesgo de explotación adicional y, de ser así, se notifica sin demora al CSIRT para acelerar la contención.
- La comunicación pública nunca debe confirmar ni detallar técnicamente una filtración de este tipo; se limita a reconocer que existe una investigación en curso y que se han reforzado los controles de seguridad.

7.4 Manejo de Alta Presión Periodística

- Toda solicitud de entrevista, declaración o comentario de medios se canaliza exclusivamente a través del Vocero Principal o Suplente; ningún otro colaborador de INTERAFAS está autorizado a declarar.
- Ante solicitudes urgentes o simultáneas de múltiples medios, se privilegia la emisión de un comunicado formal único (numeral 9.2) antes que declaraciones individuales no coordinadas, y se evalúa la conveniencia de convocar una rueda de prensa única.
- Toda pregunta fuera del alcance de los hechos confirmados se responde con la fórmula institucional: "Esa información se encuentra en proceso de verificación; en cuanto esté confirmada, será compartida de manera oficial", evitando respuestas especulativas.

8. Coordinación Institucional (Criterio PR02-28)

La comunicación de crisis no opera de manera aislada: requiere coordinación constante con las demás funciones institucionales involucradas en la gestión del incidente, conforme a la siguiente matriz de interacción.

Instancia	Rol de Coordinación	Mecanismo de Enlace
Alta Dirección (Dirección General / Consejo Directivo)	Define el nivel de tolerancia al riesgo reputacional y autoriza mensajes de alto impacto (Nivel 3/4).	Informe ejecutivo cada ciclo de monitoreo + sesión extraordinaria del Comité de Crisis.
Equipo Técnico / CISO y área de TI	Provee la versión técnica validada de los hechos (qué se confirmó, qué sigue en investigación) y valida que ningún mensaje exponga detalles explotables.	Participación permanente en el Comité de Crisis + bitácora técnica compartida.

Equipo de Respuesta a Incidentes (CSIRT)	Informa el estado de contención, erradicación y recuperación técnica, insumo directo para las etapas de mensajes del numeral 6.	Reporte de estado al inicio de cada sesión del Comité de Crisis.
Área Jurídica	Determina obligaciones de notificación regulatoria (protección de datos, infraestructura crítica) y revisa riesgos de responsabilidad en cada comunicado.	Validación obligatoria previa a la difusión (numeral 2.2), con tiempos de respuesta máximos acordados.
Dirección de Operación Hidráulica / OT	Confirma el estado real del proceso físico de bombeo y distribución, evitando que la comunicación contradiga la realidad operativa.	Enlace directo con el Centro de Operaciones, con reporte de estado en cada ciclo de monitoreo.
Autoridades externas (reguladores, protección civil, autoridades de agua)	Reciben notificación formal y, en su caso, coordinan la respuesta pública conjunta.	Notificación por oficio + punto de contacto único designado por el Enlace Jurídico.
Recursos Humanos	Garantiza que el personal reciba información consistente con los mensajes externos, evitando contradicciones.	Comunicado interno simultáneo o previo a la difusión externa, conforme al numeral 4.1.

9. Productos de Comunicación (Criterio PR02-29)

9.1 Holding Statement Inicial

Documento breve de contención reputacional inmediata, emitido dentro de la primera hora posterior a la activación del plan, antes de contar con el detalle completo del incidente.



HOLDING STATEMENT — INTERAFAS

"INTERAFAS está al tanto de reportes relacionados con una posible afectación a sus sistemas informáticos. Hemos activado de inmediato a nuestro equipo de ciberseguridad para investigar la situación y tomar las medidas necesarias. La prioridad de INTERAFAS es garantizar la seguridad de la información de nuestros usuarios y la continuidad del servicio de agua potable. Compartiremos información adicional tan pronto como sea verificada. Para consultas de medios, contactar a [Vocero Principal / correo y teléfono institucional]."

9.2 Comunicado Formal de Actualización

Documento emitido una vez que el CSIRT y el CISO han validado hechos adicionales (típicamente en las etapas de investigación o contención).

Datos verificados a la fecha del comunicado (sistemas afectados, medidas tomadas, canales de atención) según el estado del incidente en INTERAFAS-LAB: *[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]*

COMUNICADO OFICIAL — INTERAFAS

Fecha: [●] | Referencia: Incidente de Ciberseguridad [folio interno]

"INTERAFAS informa a la ciudadanía que, derivado de la investigación en curso sobre el incidente de ciberseguridad reportado el [fecha], se han confirmado las siguientes acciones: (1) aislamiento de los sistemas comprometidos; (2) refuerzo de los controles de acceso a nuestra infraestructura; (3) coordinación con especialistas externos en ciberseguridad para la remediación técnica; y (4) notificación a las autoridades competentes conforme a la normatividad aplicable. [Se confirma / No se ha confirmado] afectación al suministro de agua potable a la población. Mantendremos informada a la ciudadanía a través de nuestros canales oficiales. Para dudas, los usuarios pueden comunicarse a [línea de atención ciudadana]."

9.3 Documento de Preguntas y Respuestas (Q&A) para la Vocería

Pregunta Anticipada	Respuesta Autorizada
¿Qué pasó exactamente?	"Detectamos actividad no autorizada en algunos de nuestros sistemas informáticos. Nuestro equipo de ciberseguridad está investigando el alcance exacto y compartiremos información verificada conforme avance la investigación."
¿Está en riesgo el suministro de agua potable?	"[Confirmar según estado real de OT] Nuestro equipo de operación hidráulica monitorea de forma permanente el proceso de bombeo y distribución para garantizar la continuidad y seguridad del servicio."
¿Se robaron datos de los usuarios?	"Estamos verificando qué información pudo haber sido accedida sin autorización. En cuanto contemos con esa confirmación, notificaremos directamente a las personas potencialmente afectadas y a las autoridades correspondientes."
¿Quién es responsable de esto?	"Nuestra prioridad en este momento es la contención y protección de la información y de la operación. La determinación de causas y responsabilidades forma parte de la investigación en curso."
¿Por qué no lo informaron antes?	"Comunicamos la situación en cuanto tuvimos conocimiento confirmado de ella, siguiendo nuestros protocolos internos para evitar difundir información no verificada que pudiera generar confusión."
¿Pueden garantizar que no volverá a pasar?	"Ningún sistema está exento de riesgos; sin embargo, estamos reforzando de manera permanente nuestros controles de ciberseguridad, incluyendo la segmentación entre nuestras redes administrativas y operativas, como parte de nuestro compromiso institucional."
¿Qué debo hacer si soy usuario de INTERAFAS?	"Recomendamos a nuestros usuarios estar atentos a comunicaciones oficiales exclusivamente a través de nuestros canales institucionales, y comunicarse a [línea de atención] ante cualquier duda o actividad sospechosa relacionada con su cuenta."

9.4 Mensaje de Recuperación o Cierre de Crisis

Documento emitido al concluir formalmente la activación del plan, una vez que el CSIRT confirma la contención total y la Dirección de Operación Hidráulica confirma la normalización del proceso físico.

"INTERAFAS informa que el incidente de ciberseguridad reportado el [fecha] ha sido resuelto en su totalidad. Nuestros sistemas y procesos operativos funcionan con normalidad y hemos implementado medidas adicionales de seguridad, incluyendo [mención general de mejoras, sin detalle técnico explotable]. Agradecemos la confianza de la ciudadanía y reiteramos nuestro compromiso permanente con la protección de su información y con la operación segura y continua del servicio de agua potable. Las personas cuyos datos fueron afectados continuarán recibiendo atención personalizada a través de [canal designado]."

10. Evaluación Posterior (Criterio PR02-30)

10.1 Indicadores de Éxito

Indicador	Meta de Referencia
Tiempo entre activación del plan y emisión del holding statement	Menor o igual a 60 minutos desde la confirmación del incidente por el CSIRT.
Tiempo entre confirmación de impacto y notificación a usuarios/autoridades afectados	Conforme a los plazos regulatorios aplicables, y en todo caso dentro de las 72 horas siguientes a la confirmación.
Consistencia del mensaje	Cero contradicciones entre comunicados oficiales, declaraciones de vocería y mensajes internos durante la activación del plan.
Evolución del tono de cobertura mediática	Tendencia hacia tono neutro/informativo en un plazo máximo de 5 días posteriores al cierre del incidente, medida mediante el monitoreo del numeral 7.1.
Volumen de desinformación no corregida	Cero rumores o datos falsos de alto alcance sin respuesta o aclaración institucional dentro de las 24 horas de su detección.
Cumplimiento de la cadena de autorización	100% de los comunicados emitidos con las validaciones técnica, jurídica y ejecutiva documentadas conforme al numeral 2.2.

10.2 Registro de Decisiones (Bitácora de Crisis)

Toda decisión relevante tomada durante la activación del plan —incluyendo declaración y cambio de nivel de crisis, autorización o rechazo de mensajes, y acuerdos de coordinación interinstitucional— se registra en tiempo real por el Coordinador del Comité de Crisis en una bitácora única, con los siguientes campos mínimos:

- Fecha y hora exacta de la decisión.
- Nivel de crisis vigente al momento de la decisión.
- Descripción de la decisión tomada y su justificación.
- Responsable(s) que autorizaron la decisión, conforme a la cadena del numeral 2.2.
- Canal y, en su caso, producto de comunicación asociado (holding statement, comunicado, Q&A, mensaje de cierre).

Esta bitácora constituye el expediente oficial del manejo comunicacional del incidente y es insumo obligatorio para la evaluación posterior y para eventuales requerimientos de autoridades o auditorías internas.

10.3 Metodología de Evaluación de Resultados

Dentro de los 10 días hábiles posteriores al cierre formal del incidente, el Comité de Crisis realiza una sesión de evaluación (post-mortem de comunicación) en la que se contrastan los indicadores del numeral 10.1 contra lo efectivamente registrado en la bitácora de decisiones y en los reportes de monitoreo de medios del numeral 7.1, identificando desviaciones respecto de los tiempos y principios establecidos en el numeral 3.2.

10.4 Documentación de Lecciones Aprendidas

Como resultado de la sesión de evaluación, el Coordinador del Comité de Crisis elabora un Informe de Lecciones Aprendidas que documenta, como mínimo: (i) qué funcionó conforme a lo planeado; (ii) qué desviaciones se presentaron respecto de los tiempos, roles o principios de este plan; (iii) qué ajustes se proponen a la estructura de gobierno, los mensajes plantilla o los canales de comunicación; y (iv) un plan de acción con responsables y fechas para actualizar el presente documento. Dicho informe se integra al expediente institucional de gestión de incidentes y se presenta a la Alta Dirección, cerrando formalmente el ciclo de gestión de la crisis comunicacional.